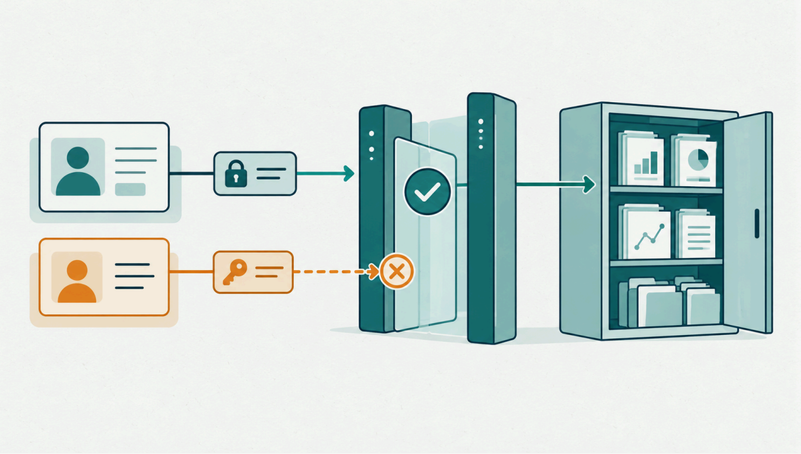
ПРИМЕЊЕНО СОФТВЕРСКО ИНЖЕЊЕРСТВО
ОСНОВЕ ИНФОРМАЦИОНЕ БЕЗБЕДНОСТИ

Идентитет, аутентикација и RBAC

Идентитет, улоге, дозволе и серверска провера приступа



Факултет техничких наука · Универзитет у Новом Саду

Нови Сад

ПРЕГЛЕД

Садржај презентације

01

Идентитет

Појмови, статус, сесије и лозинке.
04–12

02

Улоге и дозволе

RBAC, матрица права и опсег.
13–19

03

Серверска одлука

Провере, грешке и негативни тестови.
20–26

04

Ревизија и примена

Запис, доказ и рад на пројекту.
27–33

Увод

Идентитет и право приступа (03)

УВОД · ОДЛУКА О ПРИСТУПУ

Идентитет и право приступа

Аутентикација потврђује идентитет. Ауторизација одређује да ли субјекат сме да изврши конкретну радњу.

ПОЈМОВИ

Четири различита појма

Идентитет, аутентикација, улога и дозвола имају различите одговорности у систему.

ОДЛУКА

Одлука је на серверу

Интерфејс може сакрити опцију, али не сме бити једина контрола приступа.

ДОКАЗ

Дозвољено и одбијено

Тест и ревизиони запис показују шта се догодило за исти тип радње у два контекста.

ПИТАЊЕ ЗА ПРОВЕРУ

Ко је субјекат, која дозвола је потребна и у ком опсегу она важи?

ПРВИ ДЕО

01

Идентитет и пријава

Раздвајање појмова, животни циклус налога, сесија и безбедна провера лозинке.

Идентитет | Аутентикација | Сесија | Лозинка

Основни појмови контроле приступа

Идентитет, аутентикација, улога и дозвола имају засебне функције у одлуци о приступу.

01

Идентитет

Ко је субјекат?
Трајна ознака и статус.

02

Аутентикација

Да ли је тврдња о идентитету уверљива?

03

Улога

Коју пословну одговорност субјекат има?

04

Дозвола

Коју конкретну радњу сме да изврши?

МОДЕЛ ОДЛУКЕ

Ефективно право зависи од улоге, потребне дозволе, опсега и актуелног статуса идентитета.

01 · РАЗДВАЈАЊЕ ПОЈМОВА

Раздвајање аутентикације и ауторизације

Спојене провере стварају претпоставку да аутентификован корисник има право на сваку доступну радњу.

НЕБЕЗБЕДНА ПРЕТПОСТАВКА

„Пријављен је, дакле сме“

Корисник може бити исправно аутентификован, а ипак не сме да одобри промену, чита туђи ресурс или мења конфигурацију.

ПОТПУНА ОДЛУКА

„Ко, шта, над чим и зашто?“

Сервер проверава активан идентитет, потребну дозволу, опсег и контекст конкретне радње.

ЗАКЉУЧАК

Раздвајање појмова смањује број скривених пречица и омогућава јасан ревизиони траг.

Аутентикација и ауторизација

Аутентикација потврђује идентитет, док ауторизација проверава право на конкретну радњу.

ПОЈАМ	ПИТАЊЕ	ТИПИЧНА ГРЕШКА
Идентитет	Ко је субјекат?	Особа и технички налог се третирају исто.
Аутентикација	Да ли је идентитет потврђен?	Успешна пријава се тумачи као широко овлашћење.
Ауторизација	Да ли је радња дозвољена?	Провера постоји само у корисничком интерфејсу.
Сесија	У ком привременом контексту право важи?	Token се третира као трајно право.

01 · ЖИВОТНИ ЦИКЛУС

Животни циклус идентитета

Права приступа мењају се са статусом налога, организационом улогом и важењем додељених привилегија.

01
Креиран
власник и сврха налога

→

02
Активан
важеће улоге и дозволе

→

03
Промењен
нова одговорност или опсег

→

04
Суспендован
приступ се одмах укида

→

05
Угашен
остаје audit историја

ДИЗАЈНЕРСКА ПОСЛЕДИЦА

Статус идентитета и промена улоге морају утицати на сваку нову одлуку, без ослањања на застарелу претпоставку клијента.

01 · СЕСИЈЕ

Сесија као привремени безбедносни контекст

Токен преноси тврдње о субјекту у ограниченом периоду, док сервер проверава њихово важење.

01

Пријава

потврда идентитета

02

Сесија

ограничено трајање

03

Нова одлука

провера статуса и дозволе

04

Истек

поновна потврда идентитета

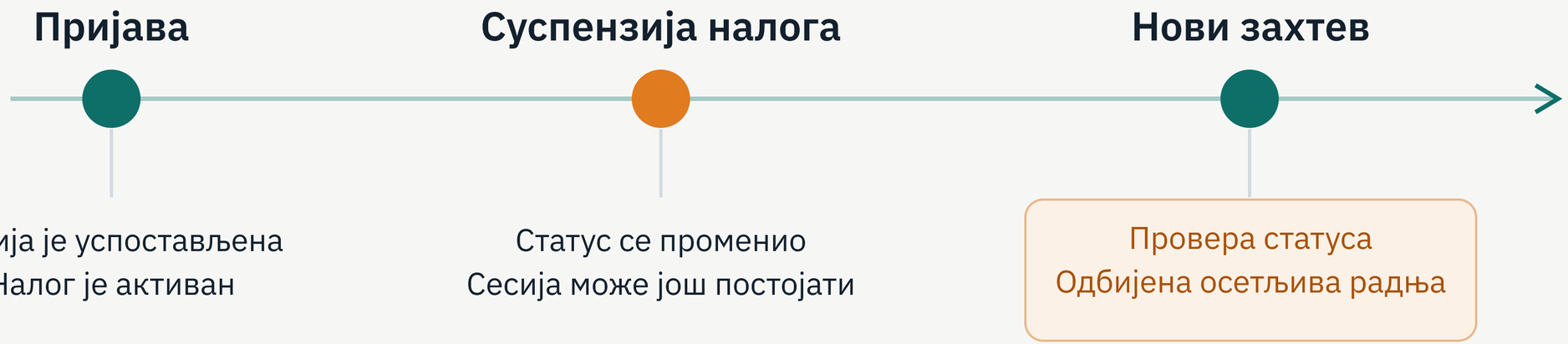
БЕЗБЕДНОСНИ ИСХОД

Суспензија мора да има ефекат

Активан токен не сме сам по себи да надјача актуелни статус идентитета за нову осетљиву радњу.

Промена статуса током сесије

Нова осетљива радња користи актуелни статус идентитета.



01 · ЛОЗИНКЕ

Безбедно чување лозинки

Систем чува изведену вредност, salt и параметре; оригинална лозинка се не може вратити.

C# · илустративни пример

```
1   public PasswordRecord Create(string password)
2   {
3       var hash = hasher.HashPassword(user, password);
4       return new PasswordRecord(hash);
5   }
```

Хеш и salt

Стандардна библиотека управља хеширањем и salt вредношћу.

Порука клијенту

Иста порука покрива непостојећи налог и погрешну лозинку.

Промена лозинке

Промена укида стару тајну и оставља ревизиони траг.

01 · C# ПРИМЕР

Резултат провере лозинке

C# · илустративни пример

```
1   public bool Verify(string password, string hash)
2   {
3       var result = hasher.VerifyHashedPassword(
4           user, hash, password);
5       if (result == PasswordVerificationResult.Failed)
6           return false;
7       if (result == PasswordVerificationResult.SuccessRehashNeeded)
8       {
9           user.PasswordHash = hasher.HashPassword(user, password);
10          SaveUpdatedHash(user);
11      }
12      return true;
13  }
```

Успешна провера

Success и SuccessRehashNeeded потврђују лозинку.

Обнова хеша

SuccessRehashNeeded захтева нов хеш и чување ажурираног записа.

ДРУГИ ДЕО

02

Улоге и дозволе

Пословна одговорност групише дозволе, а опсег и важење ограничавају њихову примену.

RBAC

Најмања привилегија

Опсег

Важење

02 · RBAC

RBAC и пословна одговорност

Улога групише ограничен скуп дозвола које одговарају одређеној пословној одговорности.

СУБЈЕКАТ

Оператер

Активан идентитет коме је додељена одговорност у одређеном домену.

УЛОГА

Оператер извештаја

Група малих дозвола које имају заједничко пословно значење.

ДОЗВОЛЕ

Преглед, Извоз

Конкретне радње, проверене серверски и ограничене опсегом.

ПРИНЦИП

Најмања привилегија: додели само право које је потребно, за опсег у коме је потребно и док потреба траје.

02 · НАЗИВИ

Именовање улога и дозвола

Назив улоге описује пословну одговорност, а назив дозволе конкретну заштићену радњу.

ПРЕШИРОКО

Admin

Назив не објашњава које радње су оправдане, над којим ресурсима и колико дуго право важи.

ПРЕЦИЗНО

Оператер извештаја

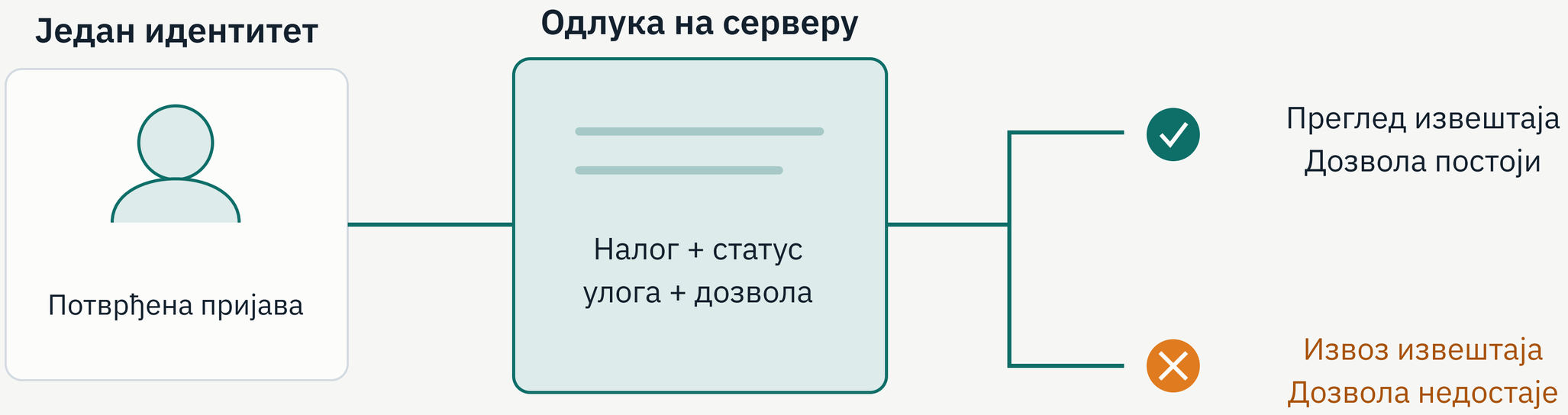
Улога групише дозволе report.view и report.export у опсегу домена за који оператер одговара.

ПРАВИЛО МОДЕЛА

Промена пословне одговорности мења улогу. Нова техничка операција додаје малу дозволу у постојећи модел.

Један идентитет, различите радње

Илустративни пример: улога има report.view, а нема report.export.



02 · ИЛУСТРАТИВНИ ПРИМЕР

Матрица улога и дозвола

Свака колона представља једну радњу, а сваки ред једну пословну одговорност.

Улога	report.view	report.export	report.approve
Читалац	Дозвољено	Одбијено	Одбијено
Оператер извештаја	Дозвољено	Дозвољено	Одбијено
Одобравалац	Дозвољено	Одбијено	Дозвољено

Илустративни модел

Матрица приказује дозволе улога. Приступ конкретном извештају захтева и проверу опсега.

02 · ИЛУСТРАТИВНИ ПРИМЕР

RBAC и приступ конкретном ресурсу

Постојање дозволе за радњу само по себи не доказује право над сваким ресурсом.

УЛОГА

Оператер извештаја

Улога додељује дозволу report.export.

РЕСУРС

Извештај домена А

Сервер учитава домен ресурса из поузданог извора.

ОПСЕГ

Додељени домен А

Извоз ресурса из домена Б захтева посебно оправдано право.

Одлука

RBAC проверава дозволу из улоге. Додатна провера ресурса, статуса и важења спречава приступ ван оправданог опсега.

02 · ПРИВРЕМЕНО ПРАВО

Привремено проширење одговорности

Широка администраторска улога додељује више права него што конкретан задатак захтева.

ПОТРЕБА

Одобравање једне врсте промене

Најпре се дефинише конкретна радња и њен ограничени опсег.

ОПСЕГ

Само један домен и ограничено време

Право важи у дефинисаном домену и престаје истеком пословне потребе.

РЕВИЗИЈА

Истек и ревизиони траг

Може се утврдити ко је доделио право, зашто и када је престало.

ЗАКЉУЧАК

Модел RBAC додељује најмању радњу оправдану пословном одговорношћу, у ограниченом опсегу и трајању.

ТРЕЋИ ДЕО

03

Серверска одлука

Јединствена провера приступа, контролисано одбијање и тестови који потврђују границу дозволе.

Активан налог | Дозвола | Опсег | Deny тест

03 · ТОК ЗАХТЕВА

Поступак доношења одлуке о приступу

Сваки корак има дефинисан улаз, исход и разлог одбијања који се може проверити.

01
Захтев
ко и шта тражи

→

02
Идентитет
потврђен и активан

→

03
Дозвола
улога и опсег

→

04
Исход
дозволи или одбиј

→

05
Audit
actor, action, target

ЗАКЉУЧАК

Клијент може да води корисника, али сервер остаје једини ауторитет за одлуку.
Одбијање треба да буде контролисано: довољно јасно клијенту, без откривања заштићених детаља.

03 · C# ПРИМЕР

Серверска провера приступа

C# · илустративни пример

```
public AccessDecision Decide(Actor actor,
    string permission, Resource target,
    IEnumerable<Role> assignedRoles)
{
    if (!actor.IsAuthenticated)
        return Deny("not_authenticated");
    if (!actor.IsActive)
        return Deny("identity_inactive");
    if (!IsInScope(actor, target))
        return Deny("out_of_scope");
```

Статус и опсег

Пријава даје идентитет. Сервер поново проверава актуелни статус и циљни ресурс.

Директан API позив

Исти захтев мора бити безбедан и када се API позове директно.

Дозвола и исход одлуке

C# · илустративни пример

```
11      var grantingRole = assignedRoles
12          .FirstOrDefault(role =>
13              Grants(role, permission));
14      return grantingRole is null
15          ? Deny("permission_not_granted")
16          : Allow("granted_by_role");
17  }
```

Именована радња

Дозвола описује конкретну радњу. Улога групише дозволе оправдане одговорношћу.

Стабилан код

Исход има стабилан код. Ревизиони запис настаје за дозвољене и одбијене покушаје.

Илустративни уговор

Deny и Allow враћају AccessDecision. assignedRoles потиче са сервера и садржи само важеће доделе.

03 · ЧЕСТЕ ГРЕШКЕ

Честе грешке у моделу приступа

Нејасно раздвајање улога, дозвола и контекста доводи до прекомерних привилегија.

01

Пријава = овлашћење

Систем не проверава посебно радњу и ресурс јер је корисник већ пријављен.

02

Преширока улога

Нова потреба се решава додавањем администратора уместо мале дозволе и опсега.

03

Сакривено дугме

Клијент не приказује радњу, али сервер прихвата директан API позив.

КОНТРАМЕРА

Заједничка контрамера обухвата експлицитну серверску одлуку, тест одбијања и ревизиони исход.

03 · NUNIT ПРИМЕР

Негативни тестови ауторизације

C# · илустративни пример

```
1   [Test]
2   public void Decide_WhenNoPermission_Denies()
3   {
4       var decision = policy.Decide(
5           ActiveActorIn("A"), "report.export",
6           ReportIn("A"), [Reader]);
7       using (Assert.EnterMultipleScope())
8       {
9           Assert.That(decision.Allowed, Is.False);
10          Assert.That(decision.Code,
11              Is.EqualTo("permission_not_granted"));
12      }
13  }
```

Радња је одбијена

Читалац има report.view, али нема report.export. Статус и опсег су исправни.

Други слој доказа

Audit бележи actor, action, target и outcome. То захтева посебну проверу тока захтева.

03 · ИЛУСТРАТИВНИ ТЕСТОВИ

Сценарији провере приступа

Сценарио	Шта мењамо	Очекивани исход
Дозвољен приступ	Активан налог, дозвола и опсег	Allow
Без пријаве	Идентитет није потврђен	not_authenticated
Суспендован налог	Идентитет је неактиван	identity_inactive
Погрешан опсег	Ресурс је у другом домену	out_of_scope
Без дозволе	Улоге не дају report.export	permission_not_granted

ЧЕТВРТИ ДЕО

04

Ревизија и примена

Ревизиони запис, поновљив доказ, припрема пројектне целине и провера разумевања.

Audit | Allow и deny | KT1 | Образложење

04 · РЕВИЗИЈА

Садржај ревизионог записа

Запис омогућава реконструкцију покушаја без чувања лозинки, токена или непотребних личних података.

JSON · илустративни запис

```json
{
  "actor": "user-184",
  "action": "report.approve",
  "target": "report-902",
  "outcome": "denied",
  "reason": "missing_permission",
  "correlationId": "c-71f2"
}
```

Реконструкција

Субјекат, радња, циљ и исход Correlation ID повезује одлуку са остатком тока захтева.

Без осетљивих вредности

Лозинка, token и непотребни лични подаци
Ревизиони траг не садржи осетљиве вредности које би могле постати нови извор цурења.

04 · ДОКАЗ ИСПРАВНОСТИ

Критеријуми исправног модела приступа

Модел обухвата позитивне и негативне сценарије, разлог одлуке и ревизиони запис.

01

Allow тест

исправна улога и опсег

02

Deny тест

недостаје једна потребна чињеница

03

Audit

actor, action, target, outcome

04

Преглед права

зашто корисник има приступ

ПРОВЕРЉИВ ЗАКЉУЧАК

Систем дозвољава оправдану радњу, одбија исту радњу без потребне дозволе и оставља траг који други члан тима може да понови и објасни.

04 · ПРОЈЕКТНА ЦЕЛИНА

Примена на пројекту

Пројектна целина треба да садржи једну серверску одлуку о приступу и проверљив доказ њеног исхода.

ИМПЛЕМЕНТАЦИЈА

Једна безбедносна одлука

Имплементација обухвата субјекат, радњу, дозволу и опсег. Серверска одлука користи актуелни статус идентитета.

ДОКАЗ

Сценарио дозволе и сценарио одбијања

Доказ обухвата тест или демонстрацију и ревизиони запис са актером, радњом, циљем и исходом.

ПРИПРЕМА ЗА КТ1

Припрема за КТ1 (у термину 4. вежбе): основна аутентикација и RBAC раде серверски. Object-level authorization и негативан тест допуњују ланац.

Примена концепата

Анализа једне радње обухвата субјекат, дозволу, контекст, серверску одлуку и доказ исхода.

01

Избор радње

на пример report.approve

→

02

Дефинисање дозволе

назив и опсег

→

03

Тест одбијања

недостаје једна чињеница

→

04

Провера ревизионог записа

actor, action, target, outcome

ОЧЕКИВАНИ РЕЗУЛТАТ

Мала серверска промена, позитиван и негативан тест и кратко објашњење зашто дозвола има баш тај опсег.

Провера разумевања

Разумевање теме подразумева објашњење одлуке, контекста и доказа независно од конкретног технолошког оквира.

ПИТАЊЕ

За једну административну радњу објасните:
ко је субјекат, која дозвола је потребна, у ком опсегу важи, шта се бележи када је радња одбијена

Можете ли исту одлуку да формулишете као allow и deny тест?

Шта се мења ако је идентитет суспендован након пријаве?

Како доказујете да UI није једина контрола приступа?

РЕЗИМЕ

Одлука о приступу и њен доказ

Аутентикација потврђује идентитет. Серверска ауторизација проверава радњу над конкретним ресурсом.

Улога групише дозволе. Актуелни статус, опсег и важење ограничавају њихову примену.

Allow и deny тестови, уз ревизиони запис, показују границу контроле.